

Knowledge Article: Contract Compliance Program Overview

Article ID: KA-0201 Category: Program Overview Last Updated: 2026-01-10

What This Program Covers

The Contract Compliance program governs how contracts, invoices, and related documents are reviewed, validated, and monitored across their lifecycle, from initial drafting through renewal or termination. It brings together requirements from several policies and SOPs that, read individually, can be hard to apply consistently. This article summarizes how they fit together.

The Core Documents and How They Relate

- **Procurement Policy (POL-PROC-001)** sets the baseline: approval thresholds by contract value, mandatory clauses every contract must contain, advance payment restrictions, and invoice tolerance rules.
- **Information Security Policy (POL-SEC-002)** adds a specific requirement on top of the Procurement Policy's general mandatory-clause list: any contract involving data access must include a compliant data privacy clause, and this cannot be waived below the Information Security Office.
- **Payment Policy (POL-PAY-003)** governs how invoices are paid once a contract is active — standard terms, milestone-based release, and overpayment prevention.
- **Vendor Risk Management Policy (POL-VRM-005)** layers additional requirements on top of the above based on a vendor's risk tier — higher-risk vendors need deeper security assessments, insurance coverage, and more frequent reassessment.
- **Data Retention and Records Management Policy (POL-DRM-006)** governs what happens to all the records this program generates — contracts, invoices, risk assessments — after the relationship ends.
- **Confidentiality Policy (POL-CONF-004)** sets the default confidentiality survival period referenced in most contract templates.

How a Contract Moves Through the Program

1. **Intake and risk tiering** (SOP-VOB-013, Part A) — before drafting even finishes, the vendor's risk tier is determined, which decides what assessments are required.
2. **Drafting and clause verification** — the contract must satisfy both the general mandatory clauses (POL-PROC-001) and, where applicable, the data privacy clause (POL-SEC-002).
3. **Approval routing** (SOP-CA-010) — routed based on contract value per the Procurement Policy threshold table, with mandatory legal review triggered above \$250,000 or for data-sharing/non-standard terms.
4. **Execution** — once approved, the contract becomes the governing document for all future invoice validation.
5. **Invoice validation** (SOP-IV-011) — every invoice submitted against the contract is checked field-by-field: supplier identity, amount, schedule, deliverables, and validity window.

6. **Renewal or offboarding** (SOP-CR-012, SOP-VOB-013 Part B) — as the contract approaches expiration, either a renewal review or a formal offboarding process is triggered, both of which reference back to the original policies to reconfirm nothing has drifted out of compliance.
7. **Retention** (POL-DRM-006) — throughout and after this lifecycle, every record generated is retained according to its type, with legal holds able to override standard disposal at any point.

Why Findings Are Categorized Pass / Warning / Fail

Not every deviation carries the same weight. A missing mandatory clause or a supplier name mismatch is treated as a **Fail** because it represents a compliance gap that blocks approval or payment outright. An invoice that exceeds tolerance but has a plausible explanation, or a payment schedule that deviates slightly from the contract, is typically a **Warning** — something a human reviewer should look at, but not necessarily a blocker. Understanding this distinction matters when interpreting the Assistant's compliance reports: a report full of Warnings is not the same risk level as one containing even a single Fail.

Where ServiceNow Fits In

Historical ServiceNow incidents are not policy — they don't define a rule the Assistant enforces. They exist to give a human reviewer context: "this exact pattern has caused a problem before." A supplier name mismatch finding becomes more actionable when the reviewer can also see that the same supplier had a similar incident logged eighteen months ago.